

January 2026 CSE 406: Cyber Security Sessional

Online 2: Ethical Hacking

Section: B1

Time: **40 minutes**

Ethical-use warning

This is an intentionally vulnerable, isolated teaching environment. Use the techniques in this assignment only against the supplied local containers. Never test an application, account, or network without explicit authorization. The same actions against a real service may be unethical and illegal.

Objective

You have access to a **Gym Check-In** portal and a **Campus Forum**. Acting through the designated attacker account, complete this unified attack:

Extract every member's remaining gym credits through SQL injection. Then use a stacked statement to place a stored-XSS payload into the designated victim's membership record, not your own. When the victim checks their real membership status while already logged in to the Campus Forum, the payload must silently post a forum message under the victim's account. That message must contain a clickable URL to the Forum search feature, and opening that exact URL must execute a reflected-XSS payload that changes the page title to **B1-REFLECTED-XSS**. The Forum message itself must remain inert until its link is opened.

Environment Setup

The Moodle archive contains `B1-images.tar`, `compose.yaml`, and this specification. From the directory containing those files, run:

```
seed@ubuntu:~$  
  
docker load --input B1-images.tar  
docker compose up -d  
docker compose ps
```

Wait until all three services are running. Open:

- Gym Check-In: `http://localhost:5000`
- Campus Forum: `http://localhost:5001`

To reset all database changes, sessions, and forum messages:

```
seed@ubuntu:~$  
  
docker compose down  
docker compose up -d
```

The 40-minute limit includes image loading and environment startup. Raise your hand immediately if Docker reports an infrastructure error before either page opens.

Credentials

Role	Member ID	Access code	Forum user	Forum password
Attacker	7700001	fit-nabila-17	nabila.chowdhury	forum-Nabila-17
Victim	7700002	fit-rafi-17	rafi.islam	forum-Rafi-17

Tasks and Marks

1. **Database extraction (2 marks):** Demonstrate SQL injection and extract every member's ID, name, and remaining class credits through the attacker submission channel.
2. **Targeted persistent modification (2 marks):** Use a stacked statement issued as member 7700001 to persist the first browser payload in member 7700002's record. The attacker's own record must remain unchanged.
3. **Victim-session CSRF (3 marks):** Demonstrate that a real login by member 7700002 to Gym Check-In triggers the stored payload and creates a Campus Forum message attributed to the victim, without the victim manually submitting the Forum form.
4. **Reflected-XSS link (3 marks):** The posted message must contain a working, clickable search URL. Opening it must change only that page's title to **B1-REFLECTED-XSS**. The script must not execute merely from viewing the ordinary Forum feed and must not persist on unrelated searches.
5. **Bonus - cover your tracks (+1):** Discover the forensic trail left by check-in submissions and delete only records attributable to member 7700001 through the same injection channel. Every other member's evidence, including the victim's, must remain.

Restrictions

- Every SQL injection, extraction request, targeted write, and cleanup used for grading must be submitted with Member ID **7700001**.
- The victim credentials may be used only to establish the victim's Forum session, trigger the planted payload through a normal membership check, and confirm the resulting Forum post. Logging in as the victim to obtain credits is not extraction.
- Direct database edits or manually posting the required Forum message do not satisfy the attack chain.
- Do not attack anything outside the supplied local environment or interfere with another student's workstation.

Submission

Create a plain-text file named with your seven-digit student ID, for example **2105XXX.txt**. Include the exact SQL and browser payloads, where each was submitted, the complete extracted roster,

and a numbered account/session sequence reproducing all three hops. Explain how the Forum post remains inert while the linked search page executes. Submit only this text file through Moodle.